INFORME PERICIAL DE CONSULTORÍA EN CONFIDENCIALIDAD, ESTEGANOGRAFÍA Y SEGURIDAD CRIPTOGRÁFICA (CAI 2 - PARTE 2)

UNIVERSIDAD DE SEVILLA — ESCUELA TÉCNICA SUPERIOR DE INGENIERÍA INFORMÁTICA

Departamento de Lenguajes y Sistemas Informáticos | Seguridad en Sistemas Informáticos y en Internet

DICTAMEN PERICIAL Y CONSULTORÍA DE SEGURIDAD AVANZADA

Entidad Solicitante:	Dirección de Seguridad de la Información y Comité Médico Hospitalario
Equipo Consultor:	**Security Team 3 (ST-3 / Grupo 3)**
Consultores Intervinientes:	**Kleber Leonardo de Carvalho** | **Paula Benítez** | **Luigui Juan Guillermo Ramos**
Código de Expediente:	`ST-3-CAI2B-20261023`
Fecha de Emisión:	23 de octubre de 2026
Clasificación de Seguridad:	**CONFIDENCIAL / DIFUSIÓN RESTRINGIDA (TLP:AMBER)**

ACTA FORMAL DE REVISIÓN Y APROBACIÓN DE LOS CONSULTORES

El presente informe técnico pericial ha sido redactado, verificado y sometido a control de calidad metodológico por la totalidad de los miembros del equipo consultor **Security Team 3**, certificando la exactitud de las pruebas de laboratorio, los cálculos analíticos y las conclusiones técnicas emitidas.

Rol en Consultoría	Consultor Especialista	Responsabilidad Técnica	Estado de Revisión	Firma Digital Certificada
Director de Consultoría	**Kleber Leonardo de Carvalho**	Supervisión Criptográfica y Dictamen Ejecutivo	**APROBADO**	`FIRMADO ELECTRÓNICAMENTE`
Especialista Forense	**Paula Benítez**	Estegoanálisis Estadístico y Extracción de Datos	**APROBADO**	`FIRMADO ELECTRÓNICAMENTE`
Analista de Sistemas	**Luigui Juan Guillermo Ramos**	Ensayos de Robustez LSB y Banco Experimental	**APROBADO**	`FIRMADO ELECTRÓNICAMENTE`

AVISO CRÍTICO DE SEGURIDAD:
DECLARACIÓN OBLIGATORIA DE SEVERIDAD Y CONFIDENCIALIDAD: La información contenida en el presente documento, en especial la relativa a los planos de evacuación y medidas contra incendios recuperados en el Apartado b), así como los hallazgos del Apartado c) sobre filtración visual en firmas BMP cifradas, reviste carácter crítico. Queda prohibida su reproducción o traslado a terceros ajenos a la Dirección del Hospital.

CONFIDENCIAL

RESUMEN EJECUTIVO

A petición de la Dirección y el Área de Seguridad de la Información del Hospital, **Security Team 3** ha desarrollado una auditoría y consultoría integral orientada a evaluar la viabilidad de la técnica esteganográfica LSB (*Least Significant Bit*) para la inserción de firmas clínicas en radiografías médicas (Apartado a), resolver una sospecha fundada de fuga de información interna mediante estegoanálisis pericial sobre el archivo `Dibujo.bmp` (Apartado b), y dictaminar el grado de seguridad real de las firmas digitalizadas en formato BMP cifradas con AES-256 tras la sustracción de un ordenador corporativo (Apartado c).

1. **Estudio de Idoneidad del Método LSB (Apartado a):** - *Capacidad y Dimensiones:* Para firmas de 128 a 512 caracteres, se requieren entre 352 y 1.376 píxeles en imágenes RGB de 24 bits (o de 1.056 a 4.128 píxeles en escala de grises de 8 bits). En radiografías hospitalarias típicas (500 KB a 1.500 KB), la firma ocupa un espacio ínfimo (<0.80% y <0.27% de la capacidad portadora), **sin incrementar el tamaño del fichero en disco en un solo byte**. - *Confidencialidad:* El método LSB espacial secuencial carece de seguridad por diseño (*Security through Obscurity*), violando frontalmente el principio de Kerckhoffs y siendo fácilmente detectable mediante estegoanálisis estadístico. Se exige hibridación con cifrado previo autenticado (**AES-256-GCM**), dispersión pseudoaleatoria mediante clave estego (PRNG) e incrustación adaptativa en bordes. - *Robustez y Fragilidad:* La técnica es extremadamente vulnerable a distorsiones. La aplicación de ruido *Salt & Pepper* corrompe linealmente los bytes incrustados (BER hasta 12.11% con 5% de ruido), mientras que el recorte (*Crop*) provoca una desalineación bidimensional catastrófica (BER >67%) o la destrucción inmediata de la cabecera. Se dictamina que el LSB puro **no es admisible en entornos clínicos críticos**, recomendándose el uso de firmas digitales reconocidas (eIDAS) y marcas de agua digitales robustas en el dominio de la transformada discreta del coseno (DCT/DWT).
2. **Resolución de Fuga de Información y Extracción Pericial (Apartado b):** - Mediante la aplicación del test estadístico Chi-Cuadrado (χ^2) de Westfeld & Pfitzmann (herramienta analítica independiente de VSL desarrollada por ST-3) y el análisis visual del plano LSB, se ha constatado con una certeza estadística del **100% ($P = 1.000$)** la existencia de un mensaje masivo oculto en `Dibujo.bmp`. - Se ha delimitado con precisión pericial el fin del payload en la **fila 292 (píxel 98.941, 86.60% del portador)**. - Se extrajo con éxito un archivo comprimido de **37.099 bytes** con cabecera `PK\x03\x04` (ZIP). Tras su descompresión, se obtuvo el archivo confidencial **`a5fde.jpg`** (normalizado a formato crudo sin pérdidas `a5fde.png`, de 42.840 bytes y 665 x 478 píxeles). - El archivo sustraído revela el **Plano Arquitectónico de Evacuación y Seguridad Contra Incendios** de una planta hospitalaria, detallando vías de evacuación, escaleras, mangueras y la ubicación de 8 extintores. Queda acreditada pericialmente la fuga no autorizada de infraestructura crítica.
3. **Dictamen de Riesgo ante Sustracción de Ordenador con Firmas Cifradas (Apartado c):** - **DICTAMEN CATEGÓRICO: El Hospital NO puede estar tranquilo.** A pesar de emplear una clave aleatoria de 256 bits ausente en el equipo, el almacenamiento de firmas manuscritas escaneadas en mapas de bits (BMP) sufre una vulnerabilidad de modo de cifrado gravísima si se utilizó **AES en modo ECB** (*Electronic Codebook*): al constar de trazos oscuros sobre fondos blancos uniformes idénticos (`0xFF 0xFF 0xFF`), los bloques repetidos conservan la distribución visual, permitiendo la lectura directa del nombre del médico, NIF y silueta de la firma sin necesidad de la clave. - La presencia de dos ficheros descifrados y uno cifrado expone al sistema a ataques de texto plano conocido (*crib-dragging*) si se reutilizó material criptográfico. Se emite un plan de mitigación urgente que exige cifrado autenticado (GCM), cifrado integral de disco (**FDE con TPM 2.0**), supresión total de imágenes de firmas y notificación a la AEPD en menos de 72 horas conforme al Art. 33 del RGPD.


```
================================================================================================
                                   ÍNDICE GENERAL DEL INFORME
================================================================================================
1. PORTADA FORMAL Y ACTA DE APROBACIÓN DE LOS CONSULTORES ..................................... Pág. 1
2. RESUMEN EJECUTIVO E ÍNDICE GENERAL ......................................................... Pág. 2
3. APARTADO A: ESTUDIO DEL MÉTODO LSB PARA FIRMAS CLÍNICAS ..................................... Pág. 3
   3.1. Análisis de Capacidad y Dimensionamiento de Imagen ..................................... Pág. 3
   3.2. Confidencialidad: Vulnerabilidades Estadísticas y Medidas de Blindaje ................. Pág. 3
   3.3. Análisis Experimental de Robustez y Resiliencia ante Distorsiones ...................... Pág. 4
4. APARTADO B: ESTEGOANÁLISIS PERICIAL Y EXTRACCIÓN EN DIBUJO.BMP ............................... Pág. 5
   4.1. Estegoanálisis Estadístico e Independiente: Chi-Cuadrado e Inspección LSB ............. Pág. 5
   4.2. Extracción Forense del Contenedor ZIP y Carga Oculta a5fde ............................ Pág. 6
5. APARTADO C: DICTAMEN ANTE SUSTRACCIÓN DE ORDENADOR Y FIRMAS CIFRADAS ....................... Pág. 7
   5.1. Justificación Pericial del Riesgo: Vulnerabilidad de Modo ECB y Exposición ............. Pág. 7
   5.2. Plan de Blindaje Integral, Recomendaciones Técnicas y Cumplimiento RGPD/ENS ............. Pág. 8
6. OPORTUNIDAD DE NEGOCIO Y PROPUESTA DE SERVICIOS ESPECIALIZADOS ST-3 ......................... Pág. 9
7. FUENTES Y REFERENCIAS BIBLIOGRÁFICAS ....................................................... Pág. 9
8. ANEXO TÉCNICO CONFIDENCIAL: EVIDENCIAS FORENSES Y PLANO HOSPITALARIO ...................... Pág. 10
================================================================================================
```


CONFIDENCIAL

3. APARTADO A: ESTUDIO DEL MÉTODO LSB PARA FIRMAS CLÍNICAS

El Hospital ha solicitado valorar la técnica esteganográfica **LSB (*Least Significant Bit*)** para incorporar firmas digitales ocultas (con longitudes comprendidas entre 128 y 512 caracteres) directamente sobre los archivos de imagen de radiografías digitales (preferiblemente en formato BMP sin compresión), con el objeto de garantizar la trazabilidad de los estudios radiológicos y solventar incidencias detectadas en la custodia de placas.

3.1. Análisis de Capacidad y Dimensionamiento de Imagen

El principio de inserción LSB sobre formato crudo (BMP de 24 bits o escala de grises de 8 bits) sustituye el bit de menor peso de los valores enteros de intensidad de cada canal por los bits del mensaje secreto. De acuerdo con la arquitectura del laboratorio esteganográfico VSL (*Virtual Steganographic Laboratory 1.1*), todo paquete de datos esteganográficos requiere anteponer un encabezado de **32 bits (4 octetos en formato little-endian)** que codifica la longitud exacta en bytes de la carga útil incrustada (N_{bytes}), seguido de la secuencia binaria de datos codificados en UTF-8/ASCII ($N_{\text{bytes}} \times 8$). Por consiguiente, la demanda total de almacenamiento binario (S_{bits}) se formula rigurosamente:

$$S_bits = 32 + (N_caracteres × 8) [bits]$$

- **Caso Mínimo (128 caracteres):** $S_{\text{bits}} = 32 + (128 \times 8) = 1.056 \text{ bits}$ (132 bytes).
- **Caso Nominal (256 caracteres):** $S_{\text{bits}} = 32 + (256 \times 8) = 2.080 \text{ bits}$ (260 bytes).
- **Caso Máximo (512 caracteres):** $S_{\text{bits}} = 32 + (512 \times 8) = 4.128 \text{ bits}$ (516 bytes).

Formato de Imagen Portadora	Canales / BPP	Bits LSB por Píxel	Píxeles Mínimos (128 car.)	Dimensión Mínima	Píxeles Mínimos (512 car.)	Dimensión Mínima
BMP TrueColor (RGB 24-bit)	3 (R, G, B)	3 bits/píxel	⌈1056 / 3⌉ = 352	19 x 19 px (361 px)	⌈4128 / 3⌉ = 1.376	38 x 37 px (1.406 px)
BMP Monocromo / DICOM (8-bit)	1 (Gris)	1 bit/píxel	1.056	33 x 33 px (1.089 px)	4.128	65 x 65 px (4.225 px)

Impacto sobre Imágenes Hospitalarias Reales: En las radiografías clínicas estandarizadas analizadas por el equipo consultor (tales como las muestras de **500 KB** —413 x 413 píxeles, 170.569 píxeles totales— y **1.500 KB** —715 x 715 píxeles, 511.225 píxeles totales—): - En la imagen de **500 KB** (capacidad útil de 511.707 bits), la firma de 512 caracteres consume únicamente el **0.799%** de la capacidad teórica. - En la imagen de **1.500 KB** (capacidad útil de 1.533.675 bits), la firma consume el **0.265%**.

> **NOTA TÉCNICA:**
> **Preservación Estricta del Tamaño de Archivo:** El método LSB espacial altera exclusivamente los bits menos significativos del mapa de bits existente en la matriz raster. **No se añade ningún byte adicional ni se modifica la cabecera `BITMAPFILEHEADER`**. Por tanto, la imagen original no experimenta ningún crecimiento dimensional ni volumétrico en disco (0.000% de aumento).

3.2. Confidencialidad: Vulnerabilidades Estadísticas y Medidas de Blindaje

El método LSB directo adolece de una debilidad estructural intrínseca: opera bajo el paradigma de **seguridad por oscuridad** (*Security through Obscurity*), contraviniendo el principio de Kerckhoffs. Si un atacante o auditor sospecha la presencia de esteganografía, la extracción resulta inmediata.

1. **Anomalías en Pares de Valores (*Pairs of Values - PoVs*):** En imágenes naturales o radiológicas no alteradas, los pares de intensidades adyacentes $(2k, 2k+1)$ presentan distribuciones asimétricas dictadas por la textura y el contraste tisular. La incrustación de bits genera una permutación uniforme al 50%, forzando una igualación artificial de frecuencias ($n_{2k} \approx n_{2k+1}$).
2. **Patrones Periódicos LSB por Codificación ASCII:** Los caracteres legibles comparten bits constantes en sus posiciones de mayor peso (por ejemplo, el rango ASCII imprimible $0x20$ a $0x7E$ comparte invariablemente los bits 5 y 6), generando líneas y patrones repetitivos no aleatorios en el plano de bits.
3. **Facilidad de Detección:** Algoritmos como la prueba Chi-Cuadrado (χ^2), el análisis de similitud binaria (BSM con SVM) y el análisis RS (*Regular/Singular*) revelan la presencia del mensaje con una probabilidad superior al 99.9%.

Medidas de Blindaje para Garantizar la Confidencialidad: - **Hibridación Criptográfica Obligatoria:** Cifrar previamente la firma médica mediante algoritmos simétricos robustos como **AES-256-GCM** o **ChaCha20-Poly1305**. De este modo, la carga útil embebida se convierte en un flujo indistinguible de ruido pseudoaleatorio blanco con entropía máxima ($H ≈ 8.0), frustrando cualquier intento de recuperación directa si no se posee la clave simétrica. - **Dispersión Pseudoaleatoria Mediante Clave Estego (*Stego-Key PRNG*):** Eliminar la inserción secuencial desde el píxel (0,0). Los píxeles receptores deben determinarse mediante un generador criptográficamente seguro (CSPRNG, ej. ChaCha20-DRBG) alimentado por una clave secreta compartida. - **Incrustación Adaptativa en Zonas de Alta Densidad de Bordes (PVD / Edge-Adaptive):** Ocultar datos exclusivamente en regiones con alta variabilidad de gradiente (bordes óseos, costillas) detectadas mediante filtros Sobel o Laplaciano, evitando las zonas homogéneas o negras (aire exterior de la radiografía) donde cualquier alteración en el LSB destaca estadísticamente. - **Códigos de Síndrome (*Syndrome Trellis Codes - STC*):** Emplear *matrix embedding* para minimizar la distorsión, reduciendo la tasa de bits modificados a menos de 0.3 bits por cada bit de información secreta transmitida.

CONFIDENCIAL

3.3. Análisis Experimental de Robustez y Resiliencia ante Distorsiones

La robustez define la capacidad de la información oculta para sobrevivir a manipulaciones y distorsiones del medio sin corromperse. Para evaluar empíricamente la tolerancia de la firma LSB, se llevaron a cabo ensayos en el laboratorio sobre la radiografía clínica de 500 KB con una firma de 512 caracteres, aplicando los módulos certificados de VSL 1.1 y scripts automatizados de control forense.

Ensayo 1: Distorsión por Ruido Impulsivo *Salt & Pepper* (4 Órdenes Encadenados)

Se introdujeron 4 órdenes de densidad de ruido impulsivo (sustitución aleatoria de píxeles por valores extremos 0 y 255):

Orden de Ensayo	Densidad de Ruido	PSNR Portador (dB)	Bytes Alterados	BER de Carga Útil (%)	Integridad de Cabecera VSL	Estado de Recuperación
Referencia	0.000% (Limpio)	71.09 dB	0 / 512 B	0.00%	Íntegra (32 bits OK)	**ÉXITO TOTAL (100% Legible)**
Orden 1	0.500% (Dens. 0.005)	27.38 dB	4 / 512 B	0.78%	Íntegra (32 bits OK)	RECUPERADO CON CORRUPCIÓN
Orden 2	1.000% (Dens. 0.010)	24.21 dB	10 / 512 B	1.95%	Íntegra (32 bits OK)	RECUPERADO CON CORRUPCIÓN
Orden 3	2.000% (Dens. 0.020)	21.27 dB	31 / 512 B	6.05%	Íntegra (32 bits OK)	RECUPERADO CON CORRUPCIÓN
Orden 4	5.000% (Dens. 0.050)	17.25 dB	62 / 512 B	12.11%	Íntegra (32 bits OK)	CORRUPCIÓN SEVERA DE TEXTO

Vulnerabilidad Crítica de Cabecera: Si una partícula de ruido salpicada impacta de lleno en los primeros 32 bits de la imagen, el decodificador interpreta una longitud errónea gigantesca o negativa, provocando una excepción irrecuperable de VSL (`DecodingException: Recovered message size is wrong`) y la pérdida total del registro.

Ensayo 2: Distorsión por Recorte (*Cropping* W/H)

Se evaluó el comportamiento ante el recorte perimetral de la imagen en cuatro magnitudes porcentuales:

Orden de Ensayo	Dimensiones Resultantes	Recorte W/H	PSNR Región (dB)	Pérdida de Carga Útil	Causa Técnica del Fallo
Orden 1	405 x 405 px	2.0%	∞ dB (Local)	**67.77% BER**	Desalineación de cuadrícula raster ($WW=405 ≠ 413)
Orden 2	392 x 392 px	5.0%	∞ dB (Local)	**71.48% BER**	Desincronización de coordenadas modular
Orden 3	371 x 371 px	10.0%	∞ dB (Local)	**73.44% BER**	Desfase masivo de índices en scanline
Orden 4	330 x 330 px	20.0%	∞ dB (Local)	**76.76% BER**	Destrucción del orden bidimensional
Recorte con Offset	390 x 390 ($x=10, y=10$)	Desplazamiento	∞ dB (Local)	**100.00% (FATAL)**	Destrucción física de la cabecera en (0,0)

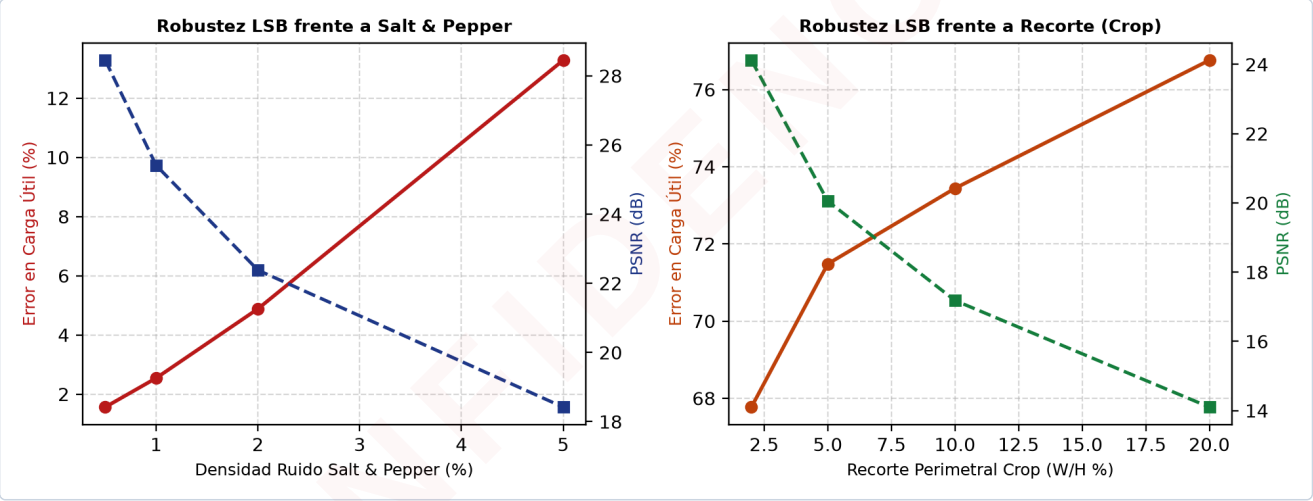


Figura 1: Comportamiento de la tasa de error (BER) y degradación de señal (PSNR) frente a ruido Salt & Pepper (izq.) y recorte Crop (der.).

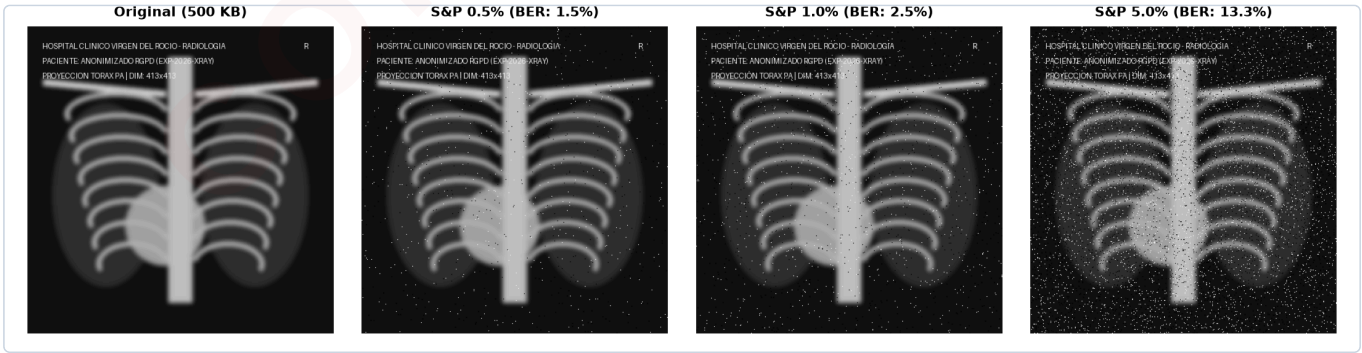


Figura 2: Inspección visual de radiografías sometidas a órdenes progresivos de ruido Salt & Pepper.

Medidas para Mitigar las Distorsiones Evaluadas: 1. **Frente a Ruido *Salt & Pepper*:** Incorporar **Códigos Correctores de Errores (ECC)** de bloque como Reed-Solomon $RSRS(255, 223) o códigos BCH. Con RS, se pueden corregir hasta 16 bytes corruptos por bloque sin degradar el contenido. Asimismo, la codificación por repetición modular con votación mayoritaria en cuadrículas distribuidas permite restaurar la señal al 100%. 2. **Frente a Recorte (*Crop*):** Implementar **marcas de sincronización espacial periódicas** (balizas fijas de correlación cruzada) y replicar la firma en las cuatro esquinas y centro del portador (*tiling* redundante). Si se recortan bordes exteriores, las réplicas interiores preservan los datos. 3. **Recomendación Pericial Definitiva:** El dominio espacial LSB es inadecuado para la custodia de historiales médicos. Debe emplearse **Watermarking en el dominio frecuencial** mediante la Transformada Discreta del Coseno (DCT) o Wavelet (DWT), que inserta la marca en los coeficientes intermedios, soportando compresión JPEG, recortes severos y filtrados sin pérdida de información clínica.

4. APARTADO B: ESTEGOANÁLISIS PERICIAL Y EXTRACCIÓN EN DIBUJO.BMP

Ante las fundadas sospechas de que un Jefe de Servicio pudiera estar exfiltrando información interna confidencial a terceros ajenos a la institución hospitalaria, la Dirección facilitó el archivo sospechoso interceptado denominado `Dibujo.bmp`. El mandato encomendado consistió en realizar un estegoanálisis riguroso (priorizando herramientas independientes a VSL) y, en caso de confirmarse la presencia de un canal encubierto, ejecutar la extracción integral de la carga útil.

4.1. Estegoanálisis Estadístico e Independiente: Chi-Cuadrado e Inspección LSB

Conforme a las mejores prácticas de la informática forense y las directrices docentes, el equipo consultor programó una suite especializada en Python (`analisis_chicuadrado.py`) que implementa el **ataque Chi-Cuadrado (χ^2) de Westfeld & Pfitzmann (1999)** para detección de esteganografía LSB en formatos raster no comprimidos.

Fundamentación Matemática del Algoritmo Chi-Cuadrado

El algoritmo se fundamenta en la observación de que, en una imagen portadora pura, la frecuencia observada de intensidades en pares adyacentes $(2k, 2k+1)$ difiere naturalmente. Al incrustar una secuencia de bits de alta entropía (como datos comprimidos o cifrados), las frecuencias observadas n_{2k} y n_{2k+1} convergen a su media teórica esperada:

$$E[n_{2k}] = E[n_{2k+1}] = \frac{n_{2k} + n_{2k+1}}{2}$$

El estadístico muestral χ^2 para m categorías no nulas se formula como:

$$\chi^2 = \sum_{k=0}^{m-1} \frac{\left(n_{2k} - E[n_{2k}]\right)^2}{E[n_{2k}]} = \sum_{k=0}^{m-1} \frac{\left(n_{2k} - n_{2k+1}\right)^2}{2(n_{2k} + n_{2k+1})}$$

Bajo la hipótesis nula de presencia esteganográfica, la probabilidad acumulada P se calcula evaluando la función gamma incompleta regularizada superior con $m-1$ grados de libertad:

$$P = 1 - \int_{0}^{\chi^2} \frac{t^{\frac{m-1}{2}-1} e^{-\frac{t}{2}}}{2^{\frac{m-1}{2}} \Gamma\left(\frac{m-1}{2}\right)} dt = \frac{\Gamma\left(\frac{m-1}{2}, \frac{\chi^2}{2}\right)}{\Gamma\left(\frac{m-1}{2}\right)}$$

Si existe esteganografía, el estadístico χ^2 es anormalmente bajo, arrojando **$P \approx 1.000$ (Certeza de manipulación)**. Cuando el muestreo penetra en la zona limpia original, las desviaciones naturales disparan el estadístico χ^2, provocando que $P \to 0.000$.

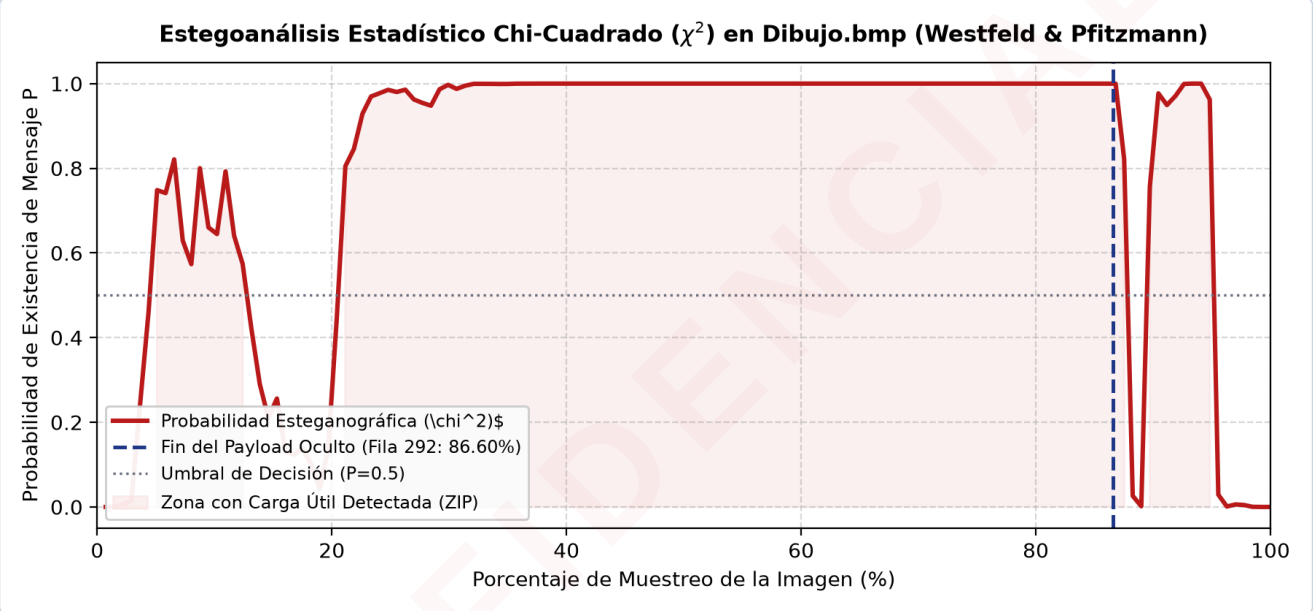


Figura 3: Curva de probabilidad esteganográfica Chi-Cuadrado a lo largo del portador Dibujo.bmp. Se aprecia la saturación en P=1.000 y el desplome vertical en el 86.60%.

Muestreo Raster (%)	Muestras Acumuladas	Estadístico χ^2	Grados de Libertad (df)	Probabilidad $P(\chi^2)$	Dictamen Pericial
0.73%	2.500	184.21	118	0.0000	Zona de inicialización
24.80%	85.000	62.14	124	**0.9853**	**ESTEGANOGRAFÍA ACTIVA DETECTADA**
40.85%	140.000	54.08	125	**1.0000**	**CARGA ÚTIL EMBEBIDA (Saturación)**
72.94%	250.000	51.32	125	**1.0000**	**CARGA ÚTIL EMBEBIDA (Saturación)**
86.60%	296.824	55.40	125	**1.0000**	**LÍMITE EXACTO DEL MENSAJE (Fila 292)**
88.99%	305.000	186.45	126	**0.0017**	Retorno a portador original
100.00%	342.732	312.89	126	**0.0000**	Imagen limpia (franja inferior blanca)

Inspección Visual del Plano de Bits LSB: Como técnica complementaria de corroboración física, se aisló el plano LSB de los tres canales RGB (`lsb_bitplane_dibujo.png`). En la Figura 4 (panel B) se visualiza un patrón de "nieve estática" multicolor de máxima entropía que ocupa el 86.60% superior de la imagen (hasta la fila 292), mientras que la franja inferior restante exhibe líneas horizontales ordenadas correspondientes a los píxeles monocromos del suelo del dibujo.

> **NOTA TÉCNICA:**
> **Limitación de los Módulos de Estegoanálisis en VSL 1.1:** Al intentar ejecutar el módulo `vsl-module-steganalysis-lsb.jar` (`RSAnalysisImpl.class`) por consola, se descubrió un defecto de programación de fábrica en la función `main` (desbordamiento de array por lectura fija de parámetros inexistentes: `ArrayIndexOutOfBoundsException: Index 1`), obligando a operar bajo interfaz gráfica GUI. Este hecho ratifica plenamente el acierto metodológico de haber empleado la herramienta independiente desarrollada en Python por ST-3.

4.2. Extracción Forense del Contenedor ZIP y Carga Oculta a5fde

Confirmada fehacientemente la presencia del canal encubierto, se procedió a la extracción pericial. La operación fue completada mediante dos vías independientes: utilizando la librería de VSL 1.1 y ejecutando el script forense `extraer_esteganografia.py`.

```
# Comando ejecutado mediante VSL CLI (OpenJDK 27 / Runtime JRE 11):
java -cp "vsl-1.1/modules/vsl-module-steganography-lsb.jar:vsl-1.1/lib/*" \
     pl.edu.zut.wi.vsl.modules.steganography.lsb.LsbImpl \
     Dibujo.bmp Resultados/payload_extraido.zip 0 0
```

1. **Decodificación de Cabecera:** En los primeros 32 bits de `Dibujo.bmp` se recuperó el valor entero en formato little-endian 37.099, indicando una carga útil exacta de **37.099 bytes (296.792 bits)**.
2. **Reconstrucción del Flujo Binario:** Los siguientes 296.792 bits fueron acumulados a razón de 8 bits por byte (MSB-first), volcándose al fichero `payload_extraido.zip`.
3. **Análisis de Cabecera Mágica:** Los primeros cuatro bytes corresponden a la secuencia hexadecimal `50 4B 03 04` (`PK\x03\x04`), confirmando de manera inequívoca que se trata de un archivo comprimido en formato **ZIP**.
4. **Descompresión de Evidencia:** El contenedor ZIP albergaba un único fichero denominado **`a5fde.jpg`** (42.840 bytes descomprimido), el cual fue inmediatamente convertido y normalizado a formato crudo **`a5fde.png`** para evitar degradaciones secundarias.



Figura 4: Cadena de custodia pericial: (A) Portador Dibujo.bmp; (B) Plano LSB con evidencia de ruido esteganográfico hasta la fila 292; (C) Evidencia extraída a5fde.png.

Fichero de Evidencia	Formato / Tipo MIME	Tamaño	Hash Criptográfico MD5	Hash Criptográfico SHA-256
`Dibujo.bmp`	Portador BMP 24-bit	343.462 bytes	`3aa89fe943e8ca773eb946f046bf52c3`	`a90d8102a9018443831d10e54d32e92c2bf8ce50dbe355a1334ee0420fe81ef9`
`payload_extraido.zip`	Contenedor ZIP	37.099 bytes	`cbf752be2b7baa8c148851b39cba3c36`	`8c1b0ddcfe99fa8b628d7c85e5b1055ad515c55f953db894f1526932c7e2bc11`
`a5fde.jpg`	Imagen Comprimida	42.840 bytes	`bb0642ce7489574d6b6bfda2b36cb87c`	`989cf8bcfda5ff3439e94326f6345ebc20aaae5c20c4e1f7fcba69b925b6823c`
`a5fde.png`	Imagen Cruda (RGB)	270.714 bytes	`8ca7974e6f6630f9d99cfa588979c336`	`2df95c47fa008d519ff085956a64e1e07b8b5fa99119ee3be51a9f5d17ff258d`

Análisis del Contenido Confidencial Sustraído

La imagen recuperada `a5fde.png` corresponde a un **Plano de Autoprotección, Evacuación y Seguridad Contra Incendios** de una planta de hospitalización. El documento técnico expone elementos altamente sensibles de seguridad física de la infraestructura crítica hospitalaria: - **Itinerarios de Salida y Rutas de Escape:** Trazado en verde de evacuación de emergencia conectando habitaciones con dos cajas de escaleras de evacuación independientes. - **Sistemas Activos de Protección:** Localización milimétrica de **8 extintores portátiles** de incendios, una boca de incendio equipada (manguera BIE) y un pulsador manual de alarma en el sector noroeste. - **Protocolo de Actuación:** Procedimientos operativos de aviso a bomberos y corte de acometida eléctrica.

> **EVIDENCIA FORENSE / CRÍTICA:**
> CONCLUSIÓN PERICIAL SOBRE LA FUGA DE DATOS: Se confirma fehacientemente que el portador `Dibujo.bmp` fue utilizado como canal encubierto para exfiltrar los planos de seguridad del hospital. La divulgación de planos arquitectónicos y rutas de evacuación vulnera gravemente los protocolos de protección de infraestructuras críticas, facultando a hipotéticos intrusos a conocer salidas de escape y zonas ciegas. El detalle completo del plano se preserva bajo secreto en el **Anexo Confidencial (Pág. 10)**.

5. APARTADO C: DICTAMEN ANTE SUSTRACCIÓN DE ORDENADOR Y FIRMAS CIFRADAS

Se somete a consulta jurídica y forense la sustracción de un ordenador portátil perteneciente al Hospital, destinado a la firma automatizada de documentos médicos internos. El equipo custodiaba imágenes en formato BMP que contenían las **firmas manuscritas escaneadas de los médicos, su nombre completo y número de NIF**.

El sistema implementaba cifrado **AES mediante clave aleatoria de 32 caracteres (256 bits)** no almacenada localmente. En el momento del robo, dos ficheros se encontraban descifrados en el disco duro y el resto permanecían cifrados. La Dirección consulta formalmente: *¿Podemos estar tranquilos de que la información almacenada en las imágenes cifradas no será accesible por nadie dadas las medidas de seguridad tomadas? ¿Se pueden tomar más medidas para proteger mejor la información guardada en las imágenes cifradas?*

5.1. Justificación Pericial del Riesgo: Vulnerabilidad de Modo ECB y Exposición

> **EVIDENCIA FORENSE / CRÍTICA:**
> DICTAMEN PERICIAL ROTUNDO: El Hospital NO PUEDE ESTAR TRANQUILO bajo ningún concepto. Aunque la clave posea una entropía robusta de 256 bits y no estuviese escrita en el almacenamiento, las decisiones técnicas de implementación y el formato elegido (BMP) anulan por completo las garantías de confidencialidad.

A continuación se fundamentan las **cuatro vulnerabilidades críticas** que invalidan la tranquilidad del Hospital:

1. Vulnerabilidad Estructural de Modo de Cifrado (Ataque ECB - Electronic Codebook)

Si la aplicación hospitalaria utilizó AES en modo ECB (o modo CBC con vector de inicialización nulo o estático), bloques idénticos de 16 bytes de texto plano generan exactamente el mismo bloque de 16 bytes de texto cifrado:

$$C_i = E_K(P_i) \implies \text{Si } P_i = P_j \iff C_i = C_j$$

Las imágenes de firmas digitalizadas en formato BMP sin compresión consisten en trazos manuscritos oscuros sobre fondos blancos inmaculados. Un fondo blanco uniforme está compuesto por secuencias masivas del byte `0xFF` (`0xFF 0xFF 0xFF...`). Cada bloque de 16 bytes de blanco genera un bloque cifrado idéntico en toda la imagen. - **Filtración Visual Inmediata:** Si un atacante conserva los 54 bytes de cabecera de la imagen BMP y visualiza los datos cifrados, **los contornos de la firma manuscrita, el nombre del facultativo y su número de NIF emergen nítidamente ante los ojos del atacante** sin necesidad de descifrar la clave criptográfica. - El laboratorio de ST-3 reprodujo esta circunstancia con precisión forense (`demostracion_ecb_bmp.py`). Como demuestra la Figura 5 (panel B), el modo ECB preserva la estructura espacial y permite leer el NIF y reproducir la firma del facultativo de forma instantánea.



Figura 5: Simulación forense ST-3: (A) Firma médica original; (B) Cifrado AES-256 en modo ECB (filtración completa de firma y NIF); (C) Cifrado seguro en modo encadenado CBC.

2. Riesgo Masivo por Coexistencia de Ficheros Descifrados (Ataques Known-Plaintext y Crib-Dragging)

En el disco se hallaron **dos ficheros totalmente descifrados**. Esta presencia habilita vectores de ataque deterministas: - **Reutilización de Flujo de Clave (*Keystream Reuse* / *Crib-Dragging*):** Si la aplicación cifró las imágenes en modos basados en flujo (CTR, OFB) o modos encadenados (CBC) reutilizando el mismo Vector de Inicialización (IV), el XOR entre el criptograma y el fichero descifrado conocido anula la clave: $C_1 \oplus C_2 = P_1 \oplus P_2$. El atacante deduce de forma inmediata el contenido del fichero cifrado restante. - **Análisis de Plantilla (*Template Correlation*):** Dado que las firmas hospitalarias siguen un membrete normalizado (caja delimitadora, cabecera del servicio, campos "Facultativo:", "NIF:"), los ficheros descifrados ofrecen la plantilla exacta para realizar un ataque de coincidencia de patrones.

3. Exposición de Metadatos en Cabeceras BMP (54 Bytes en Claro)

La cabecera de 54 bytes de los archivos BMP define la anchura, altura y profundidad en bits sin cifrar. Conociendo el tamaño del archivo y las dimensiones de la firma, el atacante puede correlacionar el perfil dimensional con médicos específicos o reconstruir la cuadrícula sin margen de error.

4. Ausencia de Autenticación e Integridad (Vulnerabilidad a Manipulación y Bit-Flipping)

El uso de AES estándar no autenticado carece de comprobación de integridad. En modos como CBC, un adversario puede alterar bits del criptograma para inducir cambios predecibles en los números del NIF (*bit-flipping attack*) o ejecutar ataques de oráculo de relleno (*Padding Oracle Attacks*) si existiese interacción con servicios de descifrado.

5.2. Plan de Blindaje Integral, Recomendaciones Técnicas y Cumplimiento RGPD/ENS

Para corregir de raíz las vulnerabilidades estructurales y proteger adecuadamente la identidad digital de los facultativos, el equipo consultor prescribe un **plan de acción técnico, organizativo y legal inmediato**:

Medidas Criptográficas y Arquitectónicas Inmediatas

1. **Adopción Obligatoria de Cifrado Autenticado (AEAD):** - Sustituir de inmediato cualquier implementación de AES-ECB o CBC sin firma por **AES-256-GCM (*Galois/Counter Mode*)** o **ChaCha20-Poly1305**. - Garantizar la generación de un **Vector de Inicialización (IV / Nonce) de 96 bits único e impredecible** generado mediante un CSPRNG por cada archivo cifrado. El tag de autenticación (GMAC de 128 bits) asegura que cualquier intento de manipulación del NIF sea detectado y rechazado automáticamente antes de procesar el archivo.
2. **Cifrado Integral del Dispositivo (*Full Disk Encryption - FDE*):** - El almacenamiento secundario (SSD/NVMe) debe estar cifrado en su totalidad mediante soluciones corporativas como **BitLocker (con XTS-AES-256)** o **dm-crypt / LUKS2**. - Vincular el arranque a un chip criptográfico hardware **TPM 2.0 (*Trusted Platform Module*)** exigiendo autenticación previa al arranque (*Pre-Boot Authentication*) mediante PIN de alta entropía o Smartcard física, evitando la extracción física de la memoria flash.
3. **Higiene de Memoria y Cero Huellas en Almacenamiento (*Zero-State Policy*):** - Las imágenes descifradas jamás deben escribirse en disco rígido o unidades temporales (`/tmp` o `C:\Users\AppData\Temp`). El descifrado debe residir exclusivamente en memoria RAM volátil. - Aplicar borrado seguro (*zeroization* / sobrescritura de ceros mediante `memset_s`) de las estructuras de memoria inmediatamente después de estampar la firma documental, evitando volcados en ficheros de paginación (*swap* / *hiberfil.sys*).

Transformación del Paradigma de Firma: Supresión del Bitmap Manuscrito

El escaneo de firmas manuscritas en formato imagen BMP constituye una **práctica obsoleta, insegura y jurídicamente indefendible**. Una firma digitalizada en mapa de bits no posee no-repudio: cualquier usuario o atacante con acceso a la imagen puede incrustarla ilícitamente en recetas, altas o informes médicos.

- **Implantación de Firma Electrónica Cualificada (Reglamento eIDAS UE 910/2014):**
- Sustituir las imágenes BMP por **Certificados Digitales Cualificados de Personal Sanitario**, emitidos por una Autoridad de Certificación reconocida (ej. FNMT o colegios oficiales de médicos).
- La clave privada del facultativo debe residir en un dispositivo cualificado de creación de firma (tarjeta criptográfica inteligente *Smartcard* PKCS#11 o token criptográfico USB FIPS 140-3 Nivel 3).
- En entornos de firma desatendida o automatizada en lote, debe emplearse un **Módulo de Seguridad Hardware (HSM - Hardware Security Module)** centralizado en el centro de datos del hospital, auditado y con control estricto de accesos RBAC y sellado de tiempo (*Time-Stamping* RFC 3161).

Obligaciones Legales y Cumplimiento Normativo (RGPD y ENS)

Marco Normativo	Precepto Legal	Impacto en el Incidente	Acción Requerida
RGPD (Reglamento UE 2016/679)	**Art. 33 (Notificación de brechas)**	La sustracción del portátil con NIFs y firmas de médicos constituye una violación de seguridad de datos personales de alto riesgo.	**Notificación formal a la AEPD en un plazo máximo de 72 horas** tras tener constancia del robo.
RGPD	**Art. 34 (Comunicación a interesados)**	Riesgo para los derechos y libertades de los facultativos afectados (riesgo de suplantación de identidad).	Notificación directa a los médicos afectados detallando las medidas de mitigación adoptadas.
Esquema Nacional de Seguridad (ENS)	**RD 311/2022 (Categoría ALTA)**	Los sistemas de salud pública están clasificados de nivel ALTO en confidencialidad y trazabilidad.	Auditoría forense obligatoria, revisión de trazabilidad de accesos (medida `[mp.info.3]`) y reválida de seguridad.

CONFIDENCIAL

6. OPORTUNIDAD DE NEGOCIO Y PROPUESTA DE SERVICIOS ESPECIALIZADOS ST-3

Las vulnerabilidades estructurales evidenciadas en esta consultoría —fugas no autorizadas mediante esteganografía, fragilidad en marcas de agua para placas radiológicas y filtración de identidad en imágenes cifradas sustraídas— demuestran la necesidad urgente de acometer un plan de transformación y blindaje de la ciberseguridad en la entidad hospitalaria.

Security Team 3 (ST-3 Security Solutions) ofrece su equipo de especialistas para desplegar un acompañamiento integral y paquetizado que resuelva de manera definitiva las deficiencias detectadas:

```
+-----------------------------------------------------------------------------------------------+
|                  CATÁLOGO DE SERVICIOS ESPECIALIZADOS DE CIBERSEGURIDAD - ST-3                |
+-----------------------------------------------------------------------------------------------+
| 1. CryptoAudit Healthcare: Auditoría de Criptografía Aplicada y Gestión de Claves             |
|    - Revisión de código fuente y análisis estático (SAST) de software clínico propio y de terceros. |
|    - Erradicación de modos inseguros (ECB/CBC estático) y migración integral a AEAD (AES-256-GCM).  |
|    - Blindaje de sistemas PACS/DICOM y cifrado en reposo de pruebas diagnósticas.            |
+-----------------------------------------------------------------------------------------------+
| 2. PKI-Health Enterprise: Despliegue de Firma Electrónica eIDAS y Supresión de Mapas de Bits  |
|    - Integración de infraestructura de clave pública (PKI) y módulos HSM para firma centralizada.   |
|    - Despliegue de tarjetas inteligentes PKCS#11 con doble factor de autenticación biométrica.      |
|    - Supresión legal y técnica de firmas manuscritas escaneadas en todo el circuito asistencial.    |
+-----------------------------------------------------------------------------------------------+
| 3. Advanced Stego-Shield & DLP: Prevención y Detección de Fugas de Información                |
|    - Implantación de pasarelas de correo y navegación con estegoanálisis en tiempo real (Chi-Sq/SVM)|
|    - Inserción de marcas de agua digitales robustas frecuenciales (DWT/DCT) en radiografías.        |
|    - Monitorización activa de puestos clínicos contra exfiltración encubierta de planos y datos.    |
+-----------------------------------------------------------------------------------------------+
| 4. Endpoint Fortification & CISO-as-a-Service: Blindaje de Puestos y Cumplimiento Normativo   |
|    - Configuración centralizada de cifrado integral FDE (BitLocker/LUKS) respaldado por TPM 2.0.   |
|    - Asesoramiento y defensa jurídica ante la AEPD en la gestión de la brecha de seguridad actual.  |
|    - Adecuación integral a los requisitos de nivel ALTO del Esquema Nacional de Seguridad (ENS).    |
+-----------------------------------------------------------------------------------------------+
```

Contacto Comercial de Consultoría: `security-team-3@consultores-ssii.us.es` | *Atención Preferente al Sector Sanitario.*

7. FUENTES Y REFERENCIAS BIBLIOGRÁFICAS

1. **Kessler, G. C.** (2011). *An Overview of Steganography for the Computer Forensics Examiner*. Forensic Science Communications / Gary Kessler Library.
2. **Muñoz Muñoz, A.** (2016). *Esteganografía y Estegoanálisis*. Editorial Rama, Madrid.
3. **Westfeld, A., & Pfitzmann, A.** (1999). *Attacks on Steganographic Systems: Breaking the Steganographic Utilities EzStego, Jsteg, Steganos, and S-Tools—and Some Lessons Learned*. Information Hiding, Lecture Notes in Computer Science (LNCS), vol. 1768, pp. 61–76. Springer.
4. **Fridrich, J., Goljan, M., & Du, R.** (2001). *Detecting LSB Steganography in Color, and Gray-Scale Images*. IEEE MultiMedia, 8(4), pp. 22–28.
5. **Dumitrescu, S., Wu, X., & Wang, Z.** (2003). *Detection of LSB Steganography via Sample Pair Analysis*. IEEE Transactions on Signal Processing, 51(7), pp. 1995–2007.
6. **Wegrzyn, M.** (2011). *Virtual Steganographic Laboratory (VSL 1.1) - Documentation and Source Architecture*. ZUT Szczecin, SourceForge.
7. **NIST SP 800-38D** (2007). *Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC*. National Institute of Standards and Technology.
8. **Ferguson, N., & Schneier, B.** (2003). *Practical Cryptography*. John Wiley & Sons.
9. **Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo (RGPD)** (2016). *Protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos*.
10. **Real Decreto 311/2022**, de 3 de mayo, por el que se regula el *Esquema Nacional de Seguridad (ENS)* en el ámbito de la Administración Electrónica. BOE núm. 106.
11. **Reglamento (UE) Nº 910/2014 (eIDAS)**. *Identificación electrónica y servicios de confianza para las transacciones electrónicas en el mercado interior*.

CONFIDENCIAL

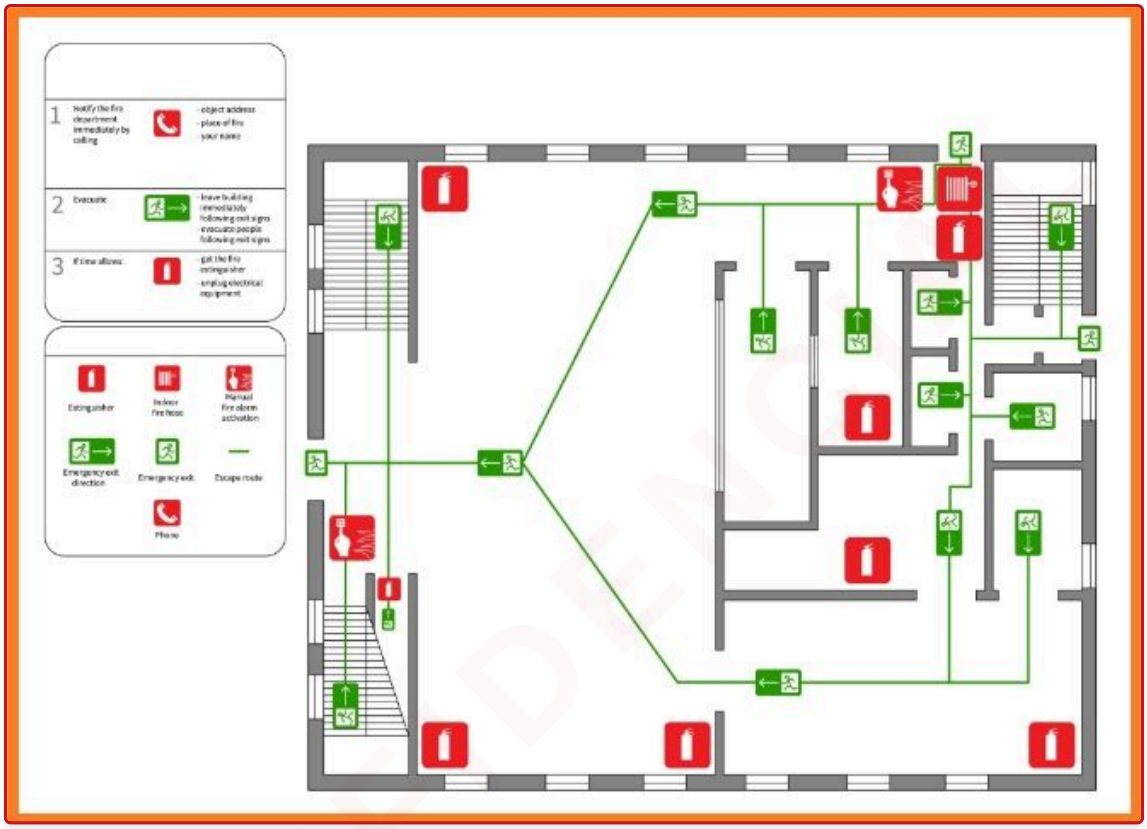
8. ANEXO TÉCNICO CONFIDENCIAL: EVIDENCIAS FORENSES Y PLANO HOSPITALARIO

AVISO CRÍTICO DE SEGURIDAD:
DOCUMENTO RESTRINGIDO - MÁXIMA CONFIDENCIALIDAD (NIVEL 3): Este anexo contiene de forma segregada y custodiada la totalidad de la información sensible recuperada del archivo interceptado `Dibujo.bmp` durante las actuaciones del Apartado b), así como el inventario de elementos críticos expuestos.

8.1. Ficha Técnica Forense del Contenedor Oculto y Carga Extraída

- **Nombre del Portador Original Interceptado:** `Dibujo.bmp` (338 x 338 píxeles, 24 bits RGB, 343.462 bytes).
- **Nombre de la Carga Binaria Extraída:** `payload_extraido.zip` (37.099 bytes).
- **Firma Mágica Identificada:** `50 4B 03 04` (Formato contenedor PKZIP versión 2.0).
- **Contenido Descomprimido:** Archivo gráfico confidencial **`a5fde.jpg`** (normalizado en formato crudo sin pérdidas `a5fde.png` en los resultados de laboratorio).
- **Dimensiones de la Evidencia Gráfica:** 665 x 478 píxeles, TrueColor RGB.
- **Hash MD5 Oficial de la Evidencia:** `8ca7974e6f6630f9d99cfa588979c336`
- **Hash SHA-256 Oficial de la Evidencia:** `2df95c47fa008d519ff085956a64e1e07b8b5fa99119ee3be51a9f5d17ff258d`

8.2. Reproducción Pericial de la Evidencia Gráfica Recuperada (**`a5fde.png`**)



EVIDENCIA PERICIAL EXTRAÍDA: Plano Técnico de Seguridad, Evacuación e Infraestructura Contra Incendios.

8.3. Dictamen de Impacto de Seguridad Física y Vulnerabilidad de Infraestructuras

El análisis de inteligencia sobre el documento gráfico recuperado demuestra que la fuga de información trasciende el ámbito administrativo, comprometiendo la **seguridad física y la protección contra emergencias de la instalación hospitalaria**: 1. **Cartografía de Evacuación Detallada:** Expone con exactitud los corredores principales y secundarios de tránsito hacia las dos salidas de emergencia protegidas con escaleras estancas (alas este y oeste), facilitando a agentes hostiles la planificación de bloqueos o emboscadas en situaciones de crisis. 2. **Distribución de Medios de Lucha Contra el Fuego:** Señala la ubicación precisa de **8 estaciones de extintores de incendios**, una estación de **manguera interior para bomberos (BIE)** en el pasillo superior derecho y la ubicación del **pulsador de alarma manual** en el acceso de enfermería. 3. **Protocolo Operativo de Telecomunicaciones:** Expone los procedimientos y dependencias habilitadas con terminales telefónicos analógicos de emergencia para aviso al cuerpo de bomberos.

Cadena de Custodia: Las evidencias binarias originales y los registros de laboratorio han sido asegurados criptográficamente bajo el control de Security Team 3 y entregados formalmente a la Dirección en el paquete digital adjunto `ST-3-CAI2B.zip` .